Cloud Security Posture Management on a Shoestring

Don Mallory

Hackfest - Québec, QC - Oct 31, 2026

Disclaimer

The thoughts and opinions shared throughout this presentation are mine alone and not those of my past, present, or future employers



- 30+ years in IT, mostly in critical infrastructure
- Healthcare security professional
- CISSP, GSEC, GCED, GCIH, and others.
- I do stuff and build community things.

Agenda

- How we got here
  - Alphabet soup
- Native toolsets

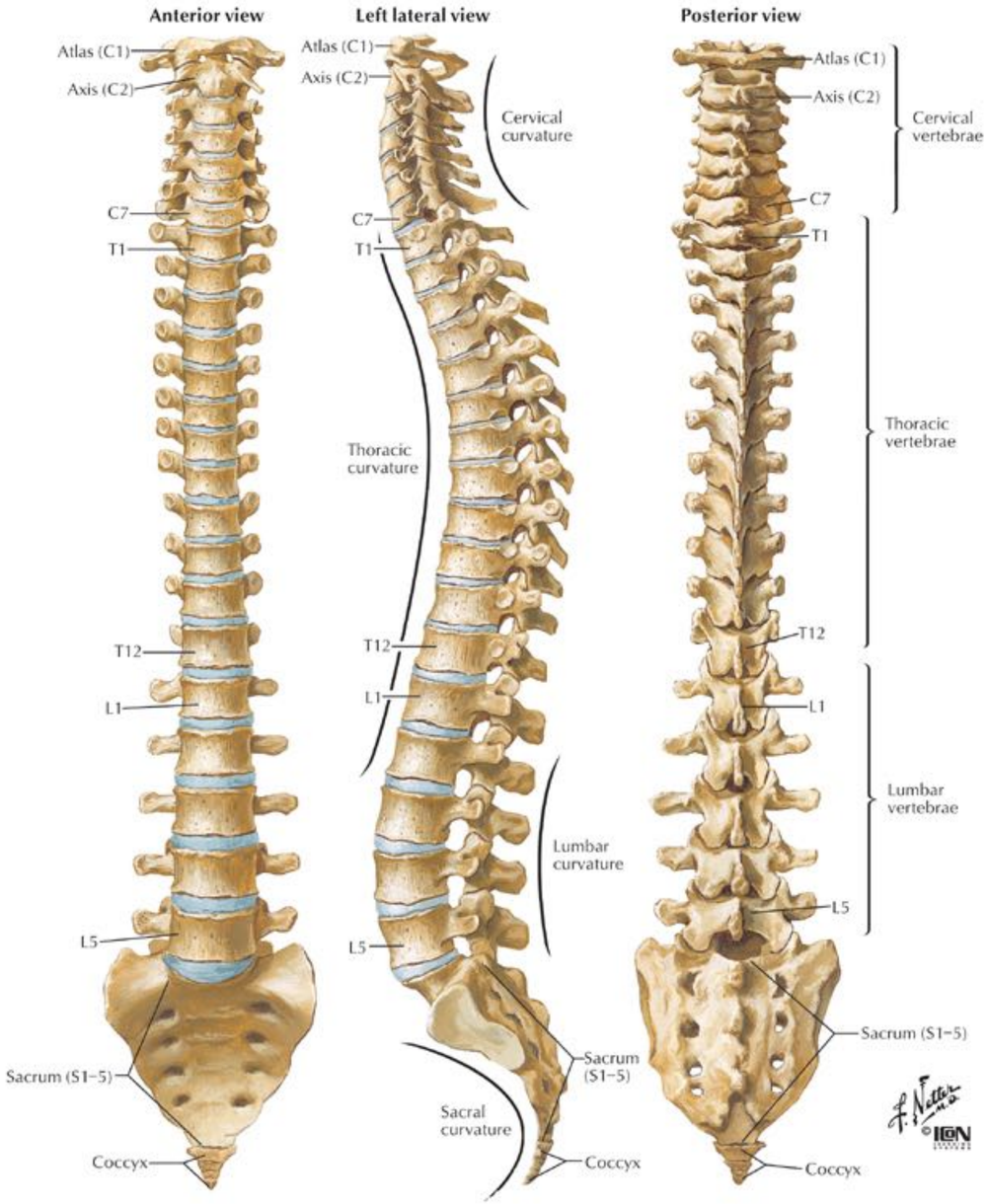
- Conclusions
- Resources, references, etc.



How is your posture?

- Postural Control
  - The ability to maintain our body in space achieving both goals of stability and orientation.

- Posture Management
  - A planned approach that includes activities and interventions aimed at influencing an individual's posture and function, tailored specifically for each individual.



How is your security posture?

A measure of the overall security status of its tools, policies, training, response plans, people, hardware, software, policies, and capabilities in place to manage defence

Security Posture Management

- The process you follow to:
  - Define your desired state
    - Legal, regulatory obligations
    - Apply standards
  - Collect evidence of current state
  - Assess and identify deviations
  - Report drift from desired state
  - Alert based on vulnerability or risk
  - Prioritise remediation



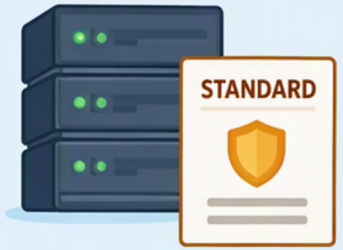
This is a process - it is not an app, a platform, or a license



Learn from history - or fail repeatedly

1 Baseline Hardening Standards

The known good standard



- Hardened baselines and “gold images”
- Mapped to policy and regulatory requirements
- Compliance measured by deviation from the baseline

Purpose
Known good standard

2 Vulnerability-Centric Assessment

Find and reduce vulnerabilities



- Network scanners
- System and service enumeration
- Credentialed scans improve signal

Purpose
Reduce vulnerabilities

3 Compliance-Centric

Prove and attest



- Meet formal frameworks and certification requirements
- Track controls, exceptions and evidence
- GRC platforms (no scanning)

Purpose
Pass certification / attestation

4 Config-Compliance

Check actual configuration



- Check secure configuration against standards
- e.g. services, logging, password policy, network ACLs
- Closest to modern “CSPM”

Purpose
Validate configuration

Open source tools timeline

- Configuration management - CFEngine, Puppet, Chef, Salt, & Ansible
- File integrity - Tripware & AIDE
- Network scanning - SATAN & nmap
- Baseline hardening standards - CIS, Bastille & OpenSCAP
- Vulnerability scanning - Nessus, OpenVAS, Nikto, Trivy
- Offensive toolsets - JTR, Metasploit, Knoppix STD, Backtrack, Kali, Hashcat
- Cloud - Trivy, ScoutSuite, Kube-bench, Prowler



Challenges with on premises tooling

Visibility



Asset inventories incomplete or stale.

Scalability



More appliances, credentials, and tickets.

Manual Remediation



Ticket processing and change management is slow.

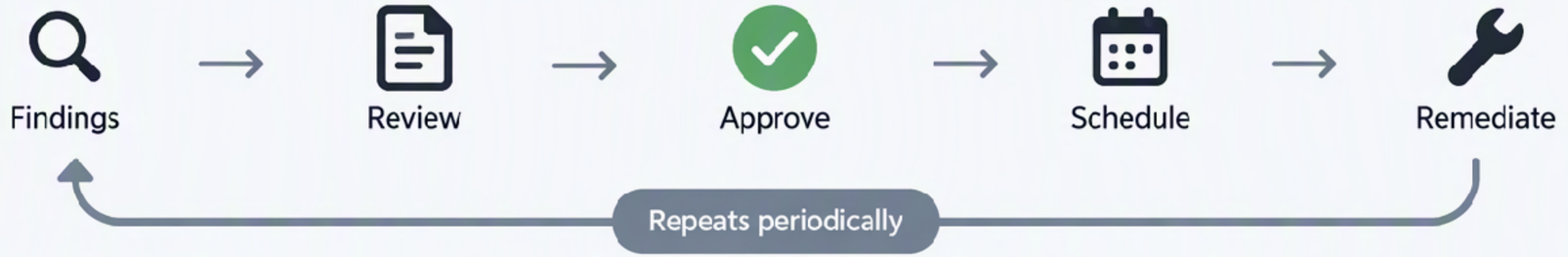
Siloing



Indicators spread across multiple tools.

Periodic

Time between review, approval, scheduling, and remediation.

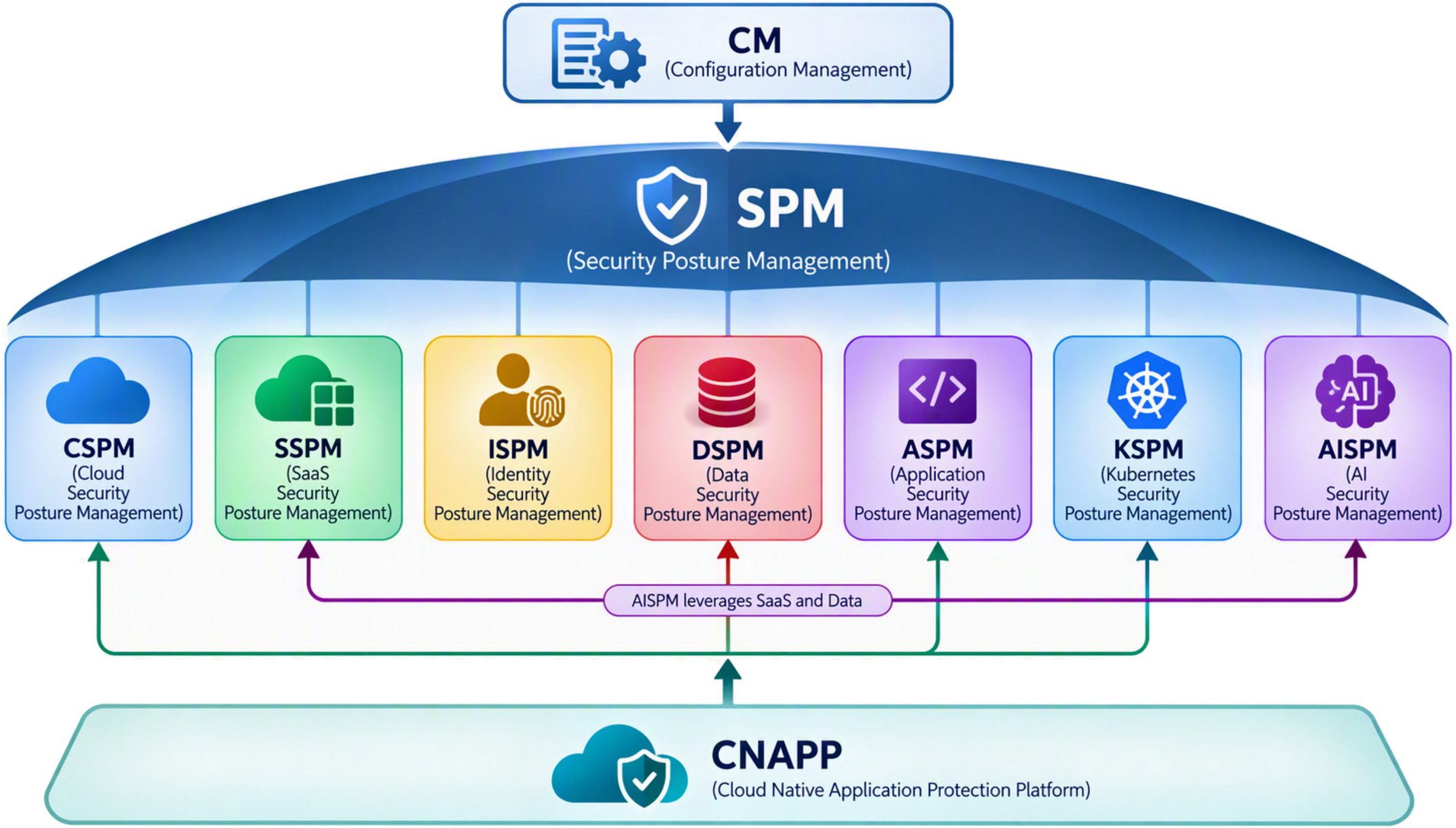




with The Cloud

- The cloud is the future
- The cloud is magical
- The cloud changed everything
- The cloud is not really someone else's computer, honest
- It brought us:
  - Resource are API-defined
  - Continuous controls evaluations
  - New types of misconfigurations
  - Vendor lock-in




CM
(Configuration Management)
SPM
(Security Posture Management)
CSPM
(Cloud Security Posture Management)
SSPM
(SaaS Security Posture Management)
ISPM
(Identity Security Posture Management)
DSPM
(Data Security Posture Management)
ASPM
(Application Security Posture Management)
KSPM
(Kubernetes Security Posture Management)
AISPM
(AI Security Posture Management)
AISPM leverages SaaS and Data
CNAPP
(Cloud Native Application Protection Platform)

Microsoft

Microsoft Cloud Posture Management

Complementary Layers, Not a Single Platform

SECURE
PEOPLE
DATA
AND AI
FOR A BRIGHTER
TOMORROW

YOUR ENVIRONMENT

Azure | Microsoft 365 | Identities | Applications | Devices | Data | Multicloud

Microsoft Defender for Cloud

- Cloud Posture
- Azure CSPM
- Multicloud

CONTROLS & CONFIGURATION

Microsoft Secure Score

- M365 Posture
- Security Score
- Adoption

MICROSOFT 365 SERVICES

Microsoft Entra Identity Posture

- Identity Posture
- MFA
- Privileged Access

IDENTITY SECURITY

Microsoft Purview Compliance Manager

- Compliance
- Assessments
- Evidence

GOVERNANCE & AUDIT

Shared Security Outcomes

Microsoft Graph | Security Standards | Risk Reduction | Continuous Improvement

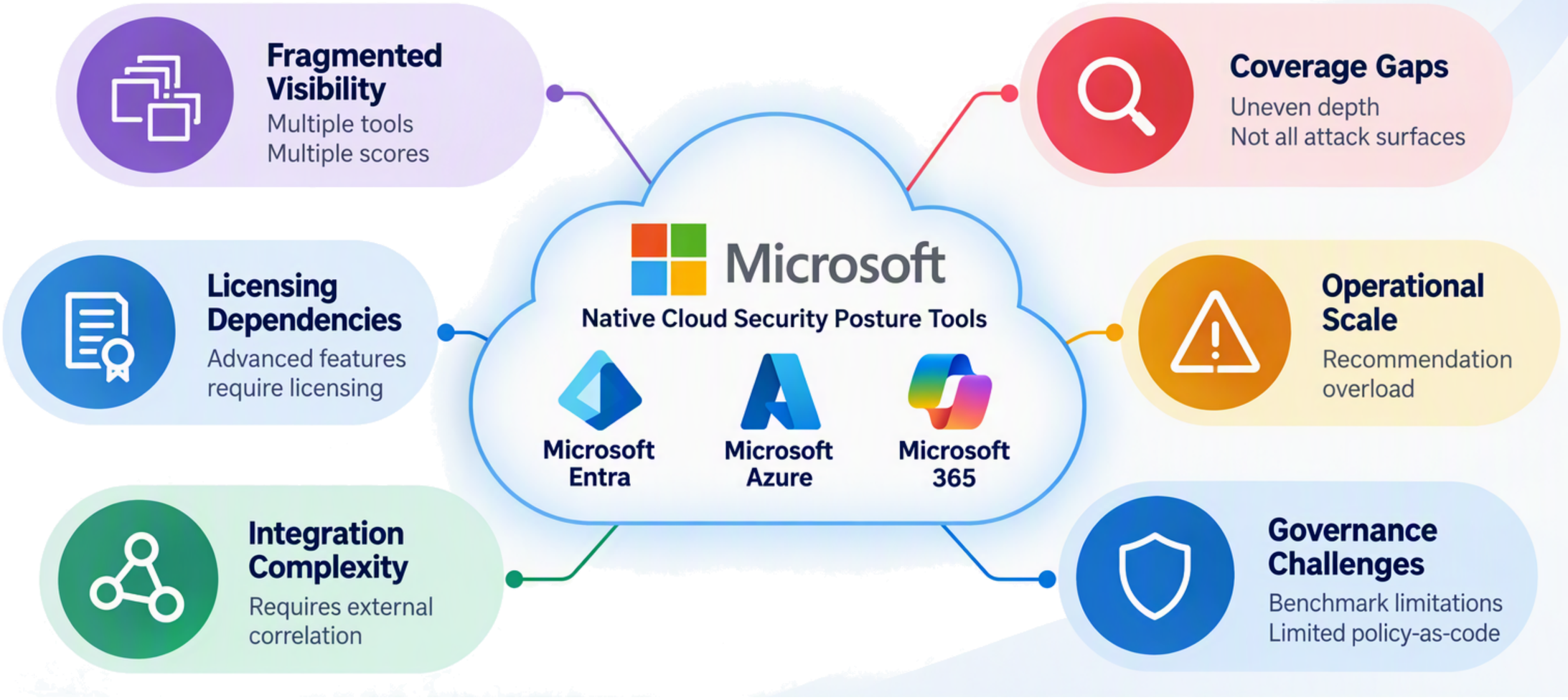
No Single Microsoft Score Represents Security Posture

CLOUD • MICROSOFT 365 • IDENTITY • COMPLIANCE

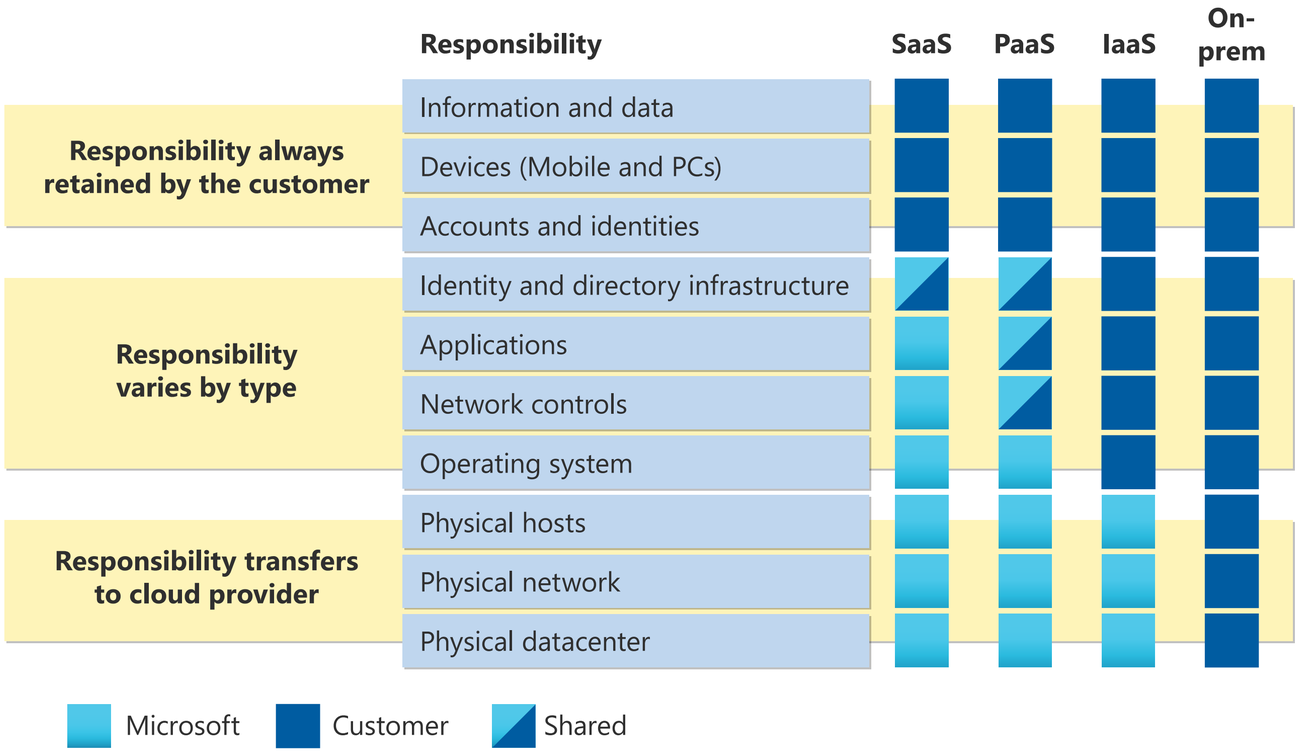
TOGETHER
FOR A MORE
RESILIENT WORLD

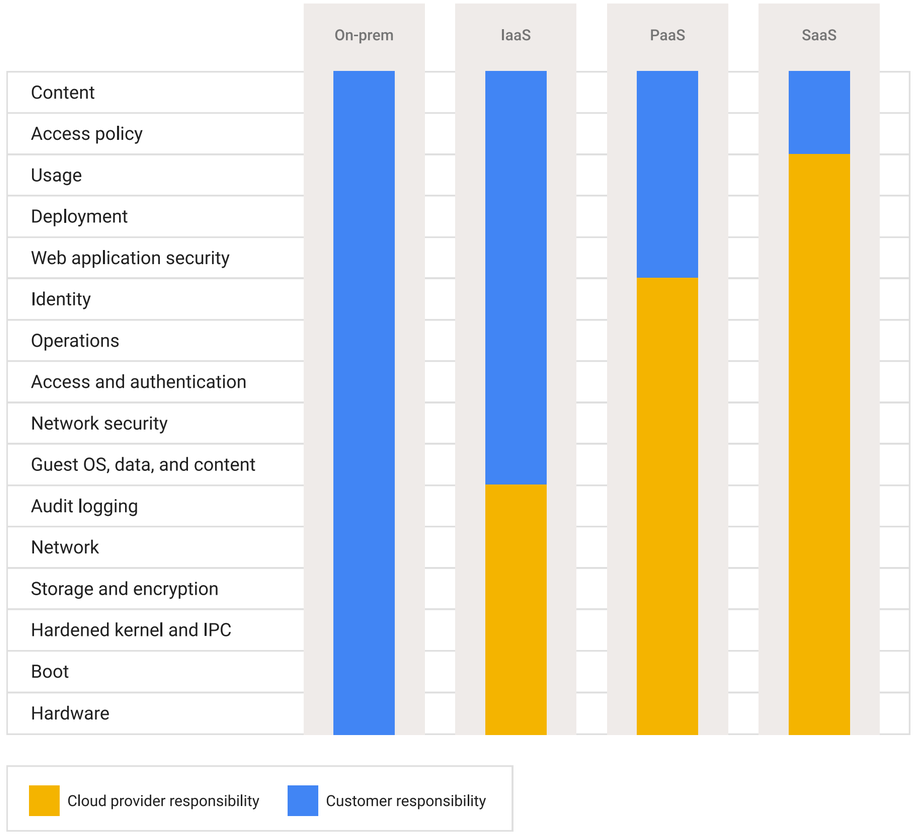
Microsoft Native CSPM:
Powerful Foundation, Not Complete Coverage

SECURE TODAY
ENABLE TOMORROW



Why do we need this anyways?





What is the problem we are trying to solve?

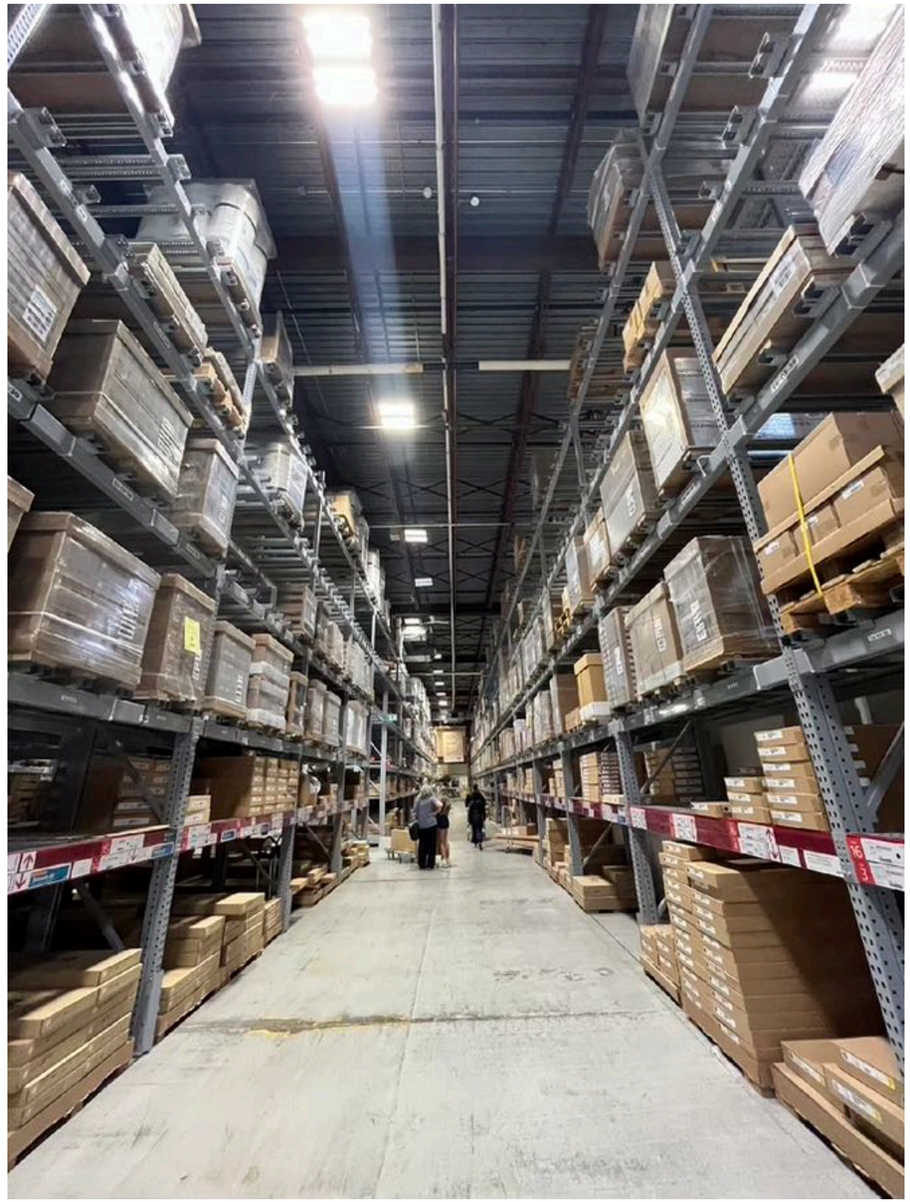




Standards First

- Benchmarks
  - CIS Benchmark
  - CISA SCB (SCuBA)
  - Microsoft Cloud Security Benchmark
  - ASD Blueprint
  - Internal Standards and Policies
  - What your regulator says

- Design your desired state
- Measure drift from that state with tools



Assessment Priorities

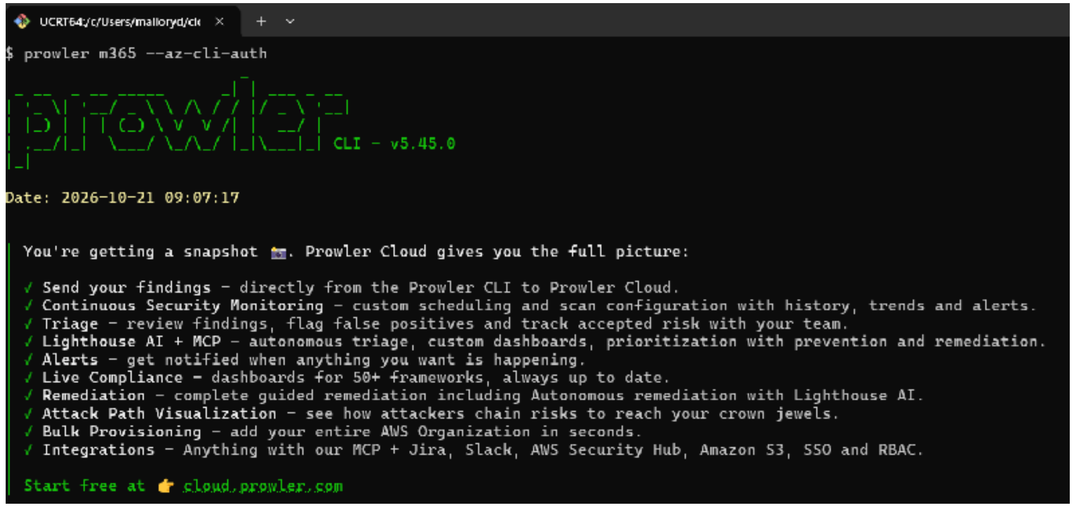
- IAM
- Cloud control plane
- Privilege Management
- Networking
- Storage
- Workloads
- Additional defensive guardrails:
- Reduce misconfigurations (CSPM)
- Enable cloud-native monitoring (Defender)
- Threat detection & response (Defender)
- Enable full-scope cloud logging (SIEM)
- Monitor the cloud control plane (drift)
- Automate alerts/detection and response (SOAR)

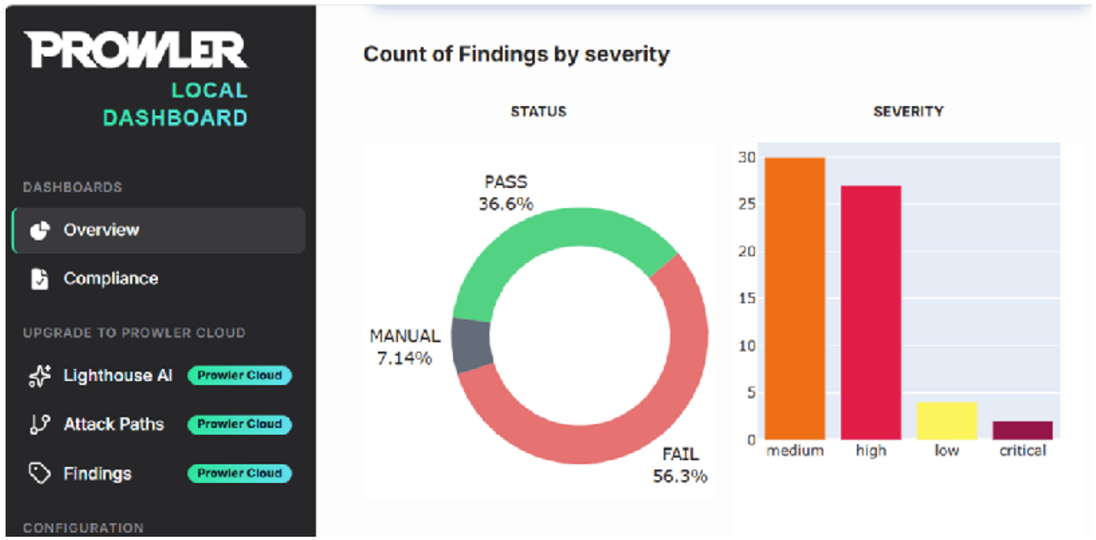


The Process


Apply Standards
Use industry and organizational standards (e.g., CIS, NIST, PCI)
Collect
Gather configuration, identity, and activity data across cloud environments
Assess
Evaluate against standards and identify risks and misconfigurations
Report
Provide visibility with dashboards and compliance reports
Alert
Notify on critical risks and policy violations
Remediate
Take action to resolve issues automatically or manually
Repeat
Continuously monitor to maintain a strong security posture
Continuous Improvement
Modernize securely. Stay compliant. Reduce risk.

But what about the tools?





- Baseline Assessment
  - ScubaGear, Steampipe
- Configuration Management
  - Microsoft365DSC, UTCM Powershell scripts
- Cloud Assessment
  - Prowler, ScoutSuite, Monkey365, M365SAT
- Identity Assessment
  - Purple Knight, SkyArk, Forest Druid, Ping Castle
- Policy as Code
  - OPA, Cloud Custodian, Checkov